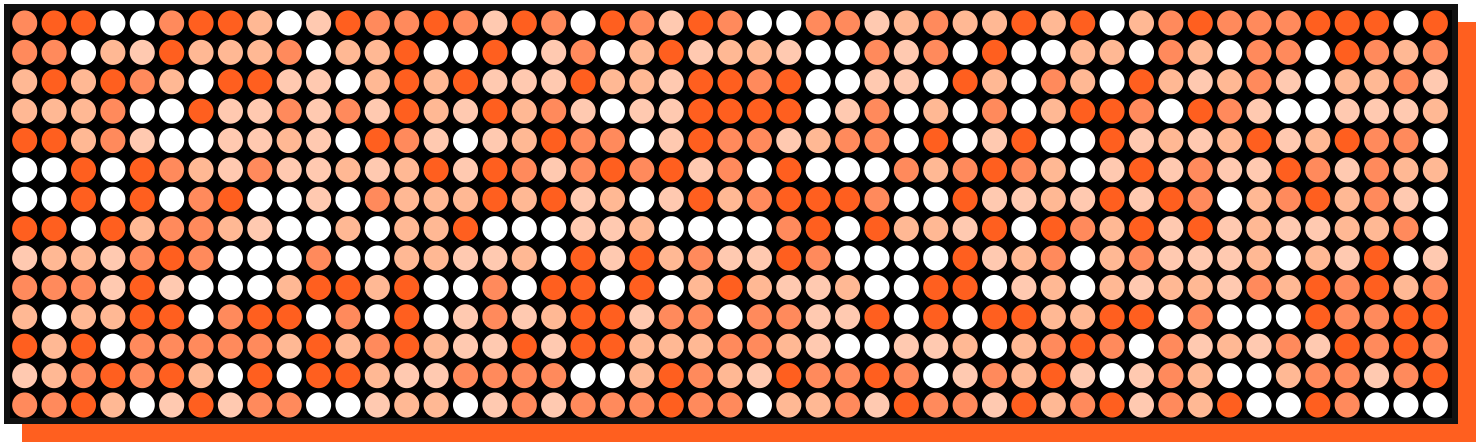
PAPYRUS EVIDENCE PACK

KNOWN GAPS AND PLAN

Controls awaiting verification, incomplete testing and dependencies on an authorized hosting environment.



RELEASE **0.1.0+3e23d44**	BUILT **2026-10-27T15:00:32Z**
IMAGE **ghcr.io/beaglabs/papyrus/papyrus**	INDEX DIGEST **sha256:d399de55560bdac84b62c098284781fd4910d3396834ca2629ebdfaa2dd0f86d**

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

KNOWN GAPS AND REMEDIATION PLAN

Open items for the Papyrus software, including controls that are partly implemented or not yet verified, testing still to be done, and dependencies on an authorized hosting environment. Controls were reviewed against Papyrus source revision `3e23d4432d3e`. The release image was built from `3e23d4432d3e`.

31	5	23	3
OPEN ITEMS	HIGH	MODERATE	LOW

The same items are in `oscal/papyrus-poam.json` (OSCAL POA&M) and `papyrus-poam.xlsx`, whose columns follow FedRAMP POA&M template headings so they can be merged into a deploying organization's own plan.

ID	ITEM	GAP	REMEDIATION	MILESTONE
PAP-001 MODERATE	**AC-2 Account Management** AC-2	A person who holds System Owner through a Papyrus role assignment keeps access while SCIM reports them deprovisioned (intended as break-glass), and there is no administrator action to end a person's active sessions.	Limit the SCIM bypass to accounts named in papyrus.yaml and audit each use; add a System Owner action to revoke a person's sessions.	Before first federal ATO package
PAP-002 MODERATE	**AC-3 Access Enforcement** AC-3	Agent sessions, their messages, the AgentFS Library and generated artifacts are owned by the tenant, not by the person who created them. Any signed-in person holding any Papyrus role can list and read every session, Library file and artifact in the deployment.	Record an owner on each session and Library namespace, enforce owner or explicit-share checks in the session, workspace-file and artifact routes, and add tests for cross-user denial.	Before first federal pilot
PAP-003 MODERATE	**AC-4 Information Flow Enforcement** AC-4	Model gateway, identity provider discovery and Sentry connections do not pass the egress gate (they are configured endpoints), and the gate does not pin the resolved address, so a host that changes its DNS answer between check and connect could reach an internal address.	Route every outbound connection through the gate and connect to the address that was checked.	Before first federal ATO package
PAP-004 MODERATE	**AC-5 Separation of Duties** AC-5	Action proposals and governed changes do not check that the approver differs from the person who proposed or requested them, so one person holding the approving roles can approve their own request. Unaddressed workflow approval steps can be answered by the run's initiator.	Refuse approval when the approver's object ID equals the proposer or requester for action proposals, governed changes and unaddressed workflow steps, with an explicit single-operator override recorded in the audit log.	Before first federal pilot
PAP-005 MODERATE	**AC-6 Least Privilege** AC-6	Possession of any role, including narrow ones such as Papyrus.Audit.View, grants access to the shared agent workspace: all sessions, chat, Library files and artifacts. Workspace access is not itself a separately assignable privilege.	Introduce a distinct workspace-use role or per-session ownership (see ac-3) so that narrow roles do not carry workspace access.	Before first federal pilot
PAP-006 MODERATE	**AC-16 Security and Privacy Attributes** AC-16	Files Papyrus generates (PDF, DOCX, XLSX, exports) are not marked, and records carry no per-item classification.	Stamp the system-high marking on generated files and exports.	Before first classified deployment
PAP-007 MODERATE	**AU-2 Event Logging** AU-2	Document downloads, session and workflow deletions, and agent tool calls are recorded in their own stores or not at all, rather than in the unified audit trail.	Write these events to the unified audit trail.	Next release
PAP-008 LOW	**AU-4 Audit Log Storage Capacity** AU-4	Papyrus does not watch free space on the data volume or alert when it runs low.	Add capacity monitoring and an alert.	Next release
PAP-009 MODERATE	**AU-9 Protection of Audit Information** AU-9	Triggers detect changes made through the application only; anyone with write access to the database file can rewrite local records, and the unified trail is not hash-chained or signed. Off-host export mitigates this only when configured.	Chain and sign the unified trail with a key held outside the data directory and verify it on a schedule; require OTLP export on classified deployments.	Before first federal ATO package

ID	ITEM	GAP	REMEDIATION	MILESTONE
PAP-010 MODERATE	**CM-2 Baseline Configuration** CM-2	The baseline is not fully reproducible: base images are referenced by tag rather than digest, apk packages are not version-pinned, and several Python packages in the runtime image (pypdf, pypdfium2, reportlab, pillow) are unpinned.	Pin base images by digest and pin apk and pip package versions, with an automated update process that opens reviewed changes.	Next release
PAP-011 LOW	**CM-8 System Component Inventory** CM-8	The SPDX SBOM records name and version only (licenses and download locations are NOASSERTION) and omits OS and Python packages; the image SBOM is not attached to the published image as a signed attestation.	Publish the image SBOM as a signed attestation alongside the provenance attestation and include license data.	Next release
PAP-012 MODERATE	**CM-14 Signed Components** CM-14	Signature verification exists only on the Marketplace VM update and image-build paths; the shell updater has no automated test, and other deployment paths do not verify signatures in this repository. The Azure template (deploy/azure/main.bicep) references ghcr.io/beaglabs/papyrus:0.1.1 by tag, a different repository from the one CI publishes (ghcr.io/beaglabs/papyrus/papyrus). Two workflows (container.yml and container-multiarch.yml) sign images for the same repository while the updater trusts only the container.yml identity.	Settle on one signing workflow and identity, reference images by digest from the published repository in every deployment template, add an automated test for the updater verification step, and document signature verification for every supported deployment path.	Next release
PAP-013 MODERATE	**IA-2 Identification and Authentication (Organizational Users)** IA-2	Papyrus does not itself require multi-factor or certificate-based authentication (it trusts the identity provider's policy) and cannot accept client certificates (CAC/PIV or SIPR tokens) directly.	Optionally require MFA or smart-card authentication methods in the token (amr/acr), and support mutual TLS with NSS PKI where the enclave requires it.	Before first classified deployment
PAP-014 HIGH	**RA-5 Vulnerability Monitoring and Scanning** RA-5	No dependency or static-analysis scanning runs in CI, and there are no severity-based remediation timeframes.	Add dependency and code scanning to CI and publish remediation timeframes.	Before first federal pilot
PAP-015 MODERATE	**SA-11 Developer Testing and Evaluation** SA-11	Most security tests, including identity, MCP and Key Vault tests, do not run in CI, and the compliance drift check runs only in the local pre-commit hook, which can be skipped. compliance/ssp.md states that these checks run in CI.	Run the full server test suite and pnpm compliance:check in CI on every pull request and make them required checks.	Next release
PAP-016 MODERATE	**SC-4 Information in Shared System Resources** SC-4	Deleting a session does not remove every copy of its content (workspace files, traces, embeddings), and there is no administrator purge for spillage.	Add a cascading purge with verification.	Before first classified deployment
PAP-017 MODERATE	**SC-5 Denial-of-Service Protection** SC-5	Rate limits are in memory and keyed on the socket address; behind the appliance's nginx proxy every client shares one address, and the limiter clears all windows once it tracks 10,000 keys. The cap of 256 pending sign-ins can be exhausted by unauthenticated requests, blocking sign-in for up to 10 minutes.	Key limits on a trusted forwarded client address, bound memory without clearing all windows, and rate-limit /api/auth/entra/login per client instead of a global cap.	Before first federal pilot
PAP-018 MODERATE	**SC-7 Boundary Protection** SC-7	The address check resolves DNS separately from the connection that follows, so a host that changes its DNS answer between the two can reach an internal address. The deployment Key Vault is created with public network access enabled.	Connect to the address that was checked (pinned lookup) for all outbound requests, and support private endpoints or firewall rules for the deployment Key Vault.	Before first federal pilot
PAP-019 MODERATE	**SC-12 Cryptographic Key Establishment and Management** SC-12	There is no rotation or key-versioning support for the portal secret or the local master key. Encryption keys for connector credentials are derived with a single SHA-256 of the portal secret, so changing that secret makes stored values unreadable. The Key Vault uses the Standard (software-protected) tier.	Introduce versioned data-encryption keys with a proper KDF, a re-encryption procedure for rotation, and an option for HSM-backed keys.	Before first federal ATO package
PAP-020 MODERATE	**SC-13 Cryptographic Protection** SC-13	Signatures and MACs use P-256 and SHA-256 rather than the CNSA suite (P-384, SHA-384) that national security systems may require.	Move Papyrus-generated signatures and MACs to CNSA algorithms while still verifying existing ones.	Before first classified deployment

ID	ITEM	GAP	REMEDIATION	MILESTONE
PAP-021 HIGH	**SC-28 Protection of Information at Rest** SC-28	Agent sessions, Library documents, audit records and traces are stored in unencrypted SQLite and AgentFS files; their confidentiality at rest depends on volume encryption the deploying organization provides.	Require and verify an encrypted volume for the data directory on classified deployments.	Before first classified deployment
PAP-022 MODERATE	**SI-2 Flaw Remediation** SI-2	Beag Labs has no documented flaw remediation timeframes by severity, and no published security advisory or vulnerability disclosure process (no SECURITY.md).	Publish a vulnerability disclosure policy and severity-based remediation SLAs, and announce fixed vulnerabilities in release notes.	Before first federal pilot
PAP-023 LOW	**SI-11 Error Handling** SI-11	Unexpected exceptions are returned to the client as 500 INTERNAL_ERROR with the exception's message text, which can disclose internal details.	Return a generic message for unmapped errors and log the detail server-side under the request ID.	Next release
PAP-024 MODERATE	**SR-4 Provenance** SR-4	GitHub Actions are referenced by mutable version tags rather than commit SHAs, and base images and OS and Python packages in the Dockerfile are not pinned, so build inputs are not fully traceable.	Pin all Actions to commit SHAs and pin image and package inputs (see cm-2), recording them in the provenance attestation.	Next release
PAP-025 HIGH	**No third-party assessment or penetration test** Program	No 3PAO assessment, independent security assessment or penetration test of Papyrus has been performed. All statements in this file are derived from the source repository and its automated tests.	Commission an independent penetration test of the application and appliance, then a 3PAO assessment against the target baseline, and track findings in the POA&M.	Before first federal ATO package
PAP-026 HIGH	**Controls not verified in an authorized hosting environment** Program	Papyrus has not been deployed or assessed within a FedRAMP-authorized or DoD Impact Level authorized boundary, and holds no ATO. The DoD image variant only changes the default Microsoft cloud and embeds the offline license key.	Deploy a reference instance in an authorized environment and verify each control there with a sponsoring agency.	Before first federal ATO package
PAP-027 HIGH	**Vulnerability scanning and remediation SLAs not formalized** Program	CI performs no dependency, static or image vulnerability scanning; there are no severity-based remediation timeframes and no published vulnerability disclosure policy.	Add scanning to CI (see ra-5), publish a disclosure policy, and adopt remediation SLAs such as those in the FedRAMP continuous monitoring guidance.	Before first federal pilot
PAP-028 MODERATE	**Incident response and contingency planning owned by the deploying organization** Program	Papyrus ships no incident response plan, contingency plan, or backup tooling. Each deploying organization must cover Papyrus in its own IR and CP documentation, and Beag Labs has no published process for notifying customers of product security incidents.	Publish customer-facing guidance for IR and backup/restore of a Papyrus deployment and a Beag Labs product security incident notification process.	Before first federal pilot
PAP-029 MODERATE	**Security tests and compliance checks not enforced in CI** Program	CI runs type checking and a subset of tests; most security tests and the compliance drift check run only locally through a pre-commit hook that can be bypassed. The generated compliance/ssp.md states that these checks also run in CI.	Run the full test suite and pnpm compliance:check as required CI checks, and correct the SSP text until they do (see sa-11).	Next release
PAP-030 MODERATE	**License signing-key custody outside assessment scope** Program	Licenses are signed offline with Beag Labs' Azure Key Vault keys (beag-master, beag-dev). Custody of and access to those keys is not documented here.	Produce a control description for the license signing keys, including custody, access and rotation.	Before first federal pilot
PAP-031 MODERATE	**Agent tool lists do not limit tool use** Program	Within an active agent session any tool the deployment offers may be used; the tools listed in an agent's signed revision record intent but are not enforced. Approval prompts, budgets and channel approvals still apply.	Where an enclave requires per-agent least functionality, restore enforcement of the signed tool list or restrict the deployment-wide tool set.	Before first classified deployment